

RAG-Augmented Multi-Agent LLM Framework for Explainable Software Vulnerability Detection Using CWE Knowledge Bases

Richa Verma (25MCSS02) Advisor: Dr. Akshay Pandey

How to run the tool, and what is still open

Where this fits

The tool can explain a Java method with a CWE page, and we have scores: a perfect score only on 12 practice files, a 0.923 score on 24 hard files we wrote, modest pattern-checker scores on six public sets, and a Juliet pair score of 9 out of 17.

This note is about using that tool without memorizing commands, and about the tests that are still not done. It does not add a new score.

The idea we started with

A result that only the author can rerun is weaker than a result someone else can rerun. The screen, the stored test sets, and the tests that run on every push are there so the path is not trapped in one person's terminal history.

We also kept a rule from the experiments: a missing run stays missing. The screen must not invent a Juliet score when the key is absent or the token limit hits.

Why we chose this way

The page calls the same functions as the command line. A second implementation would drift. The page even shows the command it is about to run, so a result can be tied back to a line in a note.

It binds only to this computer. There is no login because there is no network service. Putting the pipeline on the open internet would be a different project, with authentication and abuse questions we have not studied.

The benchmarks are stored at the same commits we measured. A newer download could change file counts and silently change a score. Pinning the files is how we keep the tables stable.

What we actually did

A web page on this computer lists the test sets, the settings, and a token budget. Starting a job runs the same code as the command line. The page shows the exact command before the job starts, so the run can be repeated later.

The page listens only on this machine, at 127.0.0.1. It has no accounts, because it is not open to a network. A missing model key stops a live run and says which setting is missing. It does not invent a score. An offline setting still runs, using the template instead of the live model.

The six public Java sets are stored in the project, with a note of where they came from and which license applies. A fresh copy of the project can score the simple checker without downloading them again.

When code is pushed, GitHub runs the unit tests. Those tests do not call Groq. They check the form, the book, the sanitizer, and the scoring math.

One job runs at a time. The free model key has a daily token cap, and two big runs would spend it twice.

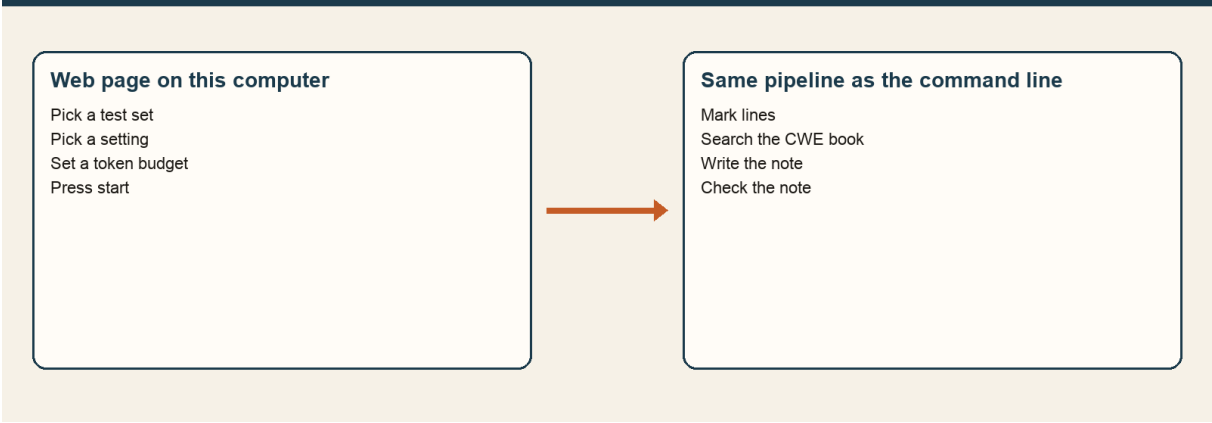
A concrete example

Open the page on this computer. Choose the seed pipeline, the test split, and the offline setting. The page prints the command it will run. The result is four practice files, scored by the template, with no call to Groq.

Choose a live Juliet run without a key and the page stops with the same message as the command line. It does not fill in a score.

The unfinished Juliet file, the search-off Juliet run, the live Vul4J slices, a second model, and the human explanation labels are still open. They need a key, tokens, or a person. This note does not close them.

Picture



The page is only a front door. The steps behind it are the same pipeline: mark lines, search, write, check.

The numbers

Still open	Why it matters	Status
Finish the Juliet file cut off by the token limit	The pair score is missing one file.	Not finished
Same Juliet pairs with search turned off	We cannot yet say whether the book helps.	Not run
Sliced real bugs from Vul4J with the live model	Public pattern-checker scores are not a model result.	Not run
A second model	We only have one live model so far.	Not run
A person marking explanations	Detection scores do not say the explanation was good.	Labels empty

Empty explanation labels stay empty. We will not fill them in to make the table look finished, and we have no agreement score between two people.

What we concluded, and why

Anyone with the project can open the page, pick an offline run, and see a note. A live run still needs a Groq key and the daily token budget.

The honest summary is unchanged by this screen: the model helps on our hard examples, the pattern checker is weak on public code, and the Juliet pair score is 9 of 17 with a wide range. The conclusion of this note is operational. The science stops where the table of open items begins.

What we are not saying

A screen is not a new scientific result. We still do not say that CWE search improves Juliet detection.